

# Report di laboratorio

## *INFORMATION GATHERING SU METASPLOITABLE*

**Studente:** Vincenzo Lembo

**Corso:** Cybersecurity & Ethical Hacking

**Esercitazione:** W10D4

**Argomento:** Information Gathering e analisi dei servizi di Metasploitable

**Ambiente:** Metasploitable, Kali Linux – UTM

---

### 1. Obiettivo dell'esercizio

L'obiettivo dell'esercizio è effettuare attività di **Information Gathering** sulla macchina Metasploitable, utilizzando diversi strumenti disponibili in Kali Linux.

L'analisi è finalizzata alla raccolta di informazioni riguardanti la raggiungibilità del target, le porte aperte, i servizi di rete attivi e le relative versioni, il sistema operativo, le tecnologie utilizzate dal server web e le informazioni esposte attraverso i servizi SMB e RPC.

Tutte le attività sono state effettuate all'interno dell'ambiente di laboratorio sulle macchine predisposte per l'esercitazione.

---

### 2. Verifica della comunicazione

Come prima operazione è stata verificata la raggiungibilità della macchina Metasploitable tramite il comando:

```
ping -c 4 192.168.50.101
```

Il target ha risposto correttamente alle richieste ICMP, confermando la comunicazione tra Kali Linux (192.168.50.100) e Metasploitable (192.168.50.101).

---

### 3. Scansione iniziale con Nmap

È stata effettuata una prima scansione delle porte mediante:

```
nmap 192.168.50.101
```

La scansione ha confermato che il target era attivo e ha individuato **23 porte TCP aperte** tra le 1.000 porte più comuni analizzate da Nmap.

Tra i principali servizi rilevati sono risultati FTP sulla porta 21, SSH sulla 22, Telnet sulla 23, SMTP sulla 25, DNS sulla 53, HTTP sulla 80, SMB sulle porte 139 e 445, NFS sulla 2049, MySQL sulla 3306, PostgreSQL sulla 5432, VNC sulla 5900 e IRC sulla 6667.

```
(kali@kali)-[~]
$ nmap 192.168.50.101
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-20 06:34 -0400
Nmap scan report for 192.168.50.101
Host is up (0.00064s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
6667/tcp  open  irc
8009/tcp  open  ajp13
8180/tcp  open  unknown
MAC Address: 96:95:E1:A3:BA:9F (Unknown)

Nmap done: 1 IP address (1 host up) scanned in 4.21 seconds
```

---

## 4. Identificazione delle versioni dei servizi

Successivamente è stata utilizzata l'opzione **-sV**:

**`nmap -sV 192.168.50.101`**

Questa scansione permette di identificare, oltre al tipo di servizio, anche il software e la relativa versione.

```
(kali@kali)-[~]
$ nmap -sV 192.168.50.101
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-20 06:36 -0400
Nmap scan report for 192.168.50.101
Host is up (0.00080s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec         netkit-rsh rexecd
513/tcp   open  login        Netkit rshd
514/tcp   open  shell        GNU Classpath gmicoregistry
1099/tcp  open  java-rmi     Metasploitable root shell
1524/tcp  open  bindshell    2-4 (RPC #100003)
2049/tcp  open  nfs          ProFTPD 1.3.1
2121/tcp  open  ftp          MySQL 5.0.51a-3ubuntu5
3306/tcp  open  mysql        PostgreSQL DB 8.3.0 - 8.3.7
5432/tcp  open  postgresql   VNC (protocol 3.3)
5900/tcp  open  vnc          (access denied)
6000/tcp  open  X11          UnrealIRCd
6667/tcp  open  irc          Apache Jserv (Protocol v1.3)
8009/tcp  open  ajp13        Apache Tomcat/Coyote JSP engine 1.1
8180/tcp  open  http         MAC Address: 96:95:E1:A3:BA:9F (Unknown)
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 16.40 seconds
```

## 5. Identificazione del sistema operativo

Per approfondire l'identificazione del sistema operativo è stato eseguito:

```
nmap -O 192.168.50.101
```

Nmap ha identificato il dispositivo come un sistema general purpose Linux e ha stimato:

- Running: Linux 2.6.X
- OS details: Linux 2.6.9 - 2.6.33
- Network Distance: 1 hop

Il risultato indica quindi un sistema Linux appartenente alla famiglia di kernel **2.6.x**.

```
(kali@kali)-[~]
$ nmap -O 192.168.50.101
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-20 06:38 -0400
Nmap scan report for 192.168.50.101
Host is up (0.0014s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
6667/tcp  open  irc
8009/tcp  open  ajp13
8180/tcp  open  unknown
MAC Address: 96:95:E1:A3:BA:9F (Unknown)
Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux_kernel:2.6
OS details: Linux 2.6.9 - 2.6.33
Network Distance: 1 hop

OS detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 5.53 seconds
```

---

## 6. Scansione completa delle porte TCP

La scansione standard di Nmap prende in considerazione principalmente le 1.000 porte TCP più comuni. Per verificare l'intero intervallo è stato quindi utilizzato:

```
nmap -p- 192.168.50.101
```

L'opzione **-p-** indica a Nmap di esaminare tutte le porte TCP comprese tra **1 e 65535**.

La scansione completa ha rilevato **30 porte aperte**, facendo emergere anche porte che non erano state visualizzate dalla scansione iniziale, tra cui:

- 3632/tcp

- 6697/tcp
- 8787/tcp
- 37392/tcp
- 39321/tcp
- 44506/tcp
- 59463/tcp

```
[kali@kali]~$ nmap -p- 192.168.50.101
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-20 06:41 -0400
Nmap scan report for 192.168.50.101
Host is up (0.00042s latency).
Not shown: 65505 closed tcp ports (reset)

PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
3632/tcp  open  distccd
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
6667/tcp  open  irc
8697/tcp  open  ircs-u
8009/tcp  open  ajp13
8180/tcp  open  unknown
8787/tcp  open  msgsrvr
37392/tcp open  unknown
39321/tcp open  unknown
44506/tcp open  unknown
59463/tcp open  unknown
MAC Address: 96:95:E1:A3:BA:9F (Unknown)

Nmap done: 1 IP address (1 host up) scanned in 5.50 seconds
```

## 7. Analisi delle porte aggiuntive

Le porte aggiuntive individuate sono state analizzate attraverso una scansione mirata:

```
nmap -sV -p 3632,6697,8787,37392,39321,44506,59463 192.168.50.101
```

Nmap ha permesso di associarle ai seguenti servizi:

- 3632/tcp distccd
- 6697/tcp UnrealIRCd
- 8787/tcp Ruby DRb RMI
- 37392/tcp nlockmgr
- 39321/tcp status
- 44506/tcp mountd
- 59463/tcp Java RMI / GNU Classpath rmiregistry

La scansione mirata ha quindi consentito di approfondire le informazioni ottenute attraverso la precedente scansione completa.

## 8. Banner grabbing con Netcat

È stato successivamente utilizzato **Netcat** per effettuare banner grabbing su alcuni dei servizi individuati.

Per FTP:

```
nc -nv 192.168.50.101 21
```

Il server ha restituito:

- 220 (vsFTPd 2.3.4)

È stata quindi confermata la presenza di **vsFTPd 2.3.4**.

La stessa operazione è stata effettuata sulla porta SSH:

```
nc -nv 192.168.50.101 22
```

ottenendo:

- SSH-2.0-OpenSSH\_4.7p1 Debian-8ubuntu1

Netcat ha quindi confermato le informazioni precedentemente ottenute mediante Nmap.

---

## 9. Analisi del server web con WhatWeb

Poiché sulla porta 80 era presente un server HTTP, è stato utilizzato WhatWeb:

```
whatweb http://192.168.50.101
```

Lo strumento ha identificato diverse tecnologie e informazioni relative al server web, tra cui:

- HTTP: 200 OK
- Apache: 2.2.8
- PHP: 5.2.4-2ubuntu5.10
- WebDAV: 2
- Sistema: Ubuntu Linux
- Titolo: Metasploitable2 - Linux

WhatWeb ha quindi permesso di integrare le informazioni ottenute con Nmap identificando ulteriori componenti della piattaforma web.

```
(root@kali: ~)
└─$ whatweb http://192.168.50.101
http://192.168.50.101 [200 OK] Apache[2.2.8], Country[RESERVED][ZZ], HTTPServer[Ubuntu Linux][Apache/2.2.8 (Ubuntu) DAV/2], IP[192.168.50.101], PHP[5.2.4-2ubuntu5.10], Title[Metasploitable2 - Linux], WebDAV[2], X-Powered-By[PHP/5.2.4-2ubuntu5.10]
```

---

# 10. Analisi del server web con Nikto

Per approfondire l'analisi del servizio HTTP è stato utilizzato Nikto:

```
nikto -h http://192.168.50.101
```

La scansione si è conclusa con **31 elementi segnalati e 0 errori**.

Tra le informazioni più significative sono state rilevate la presenza di Apache 2.2.8 e PHP 5.2.4, directory con directory indexing abilitato, presenza di `phpinfo.php`, risorse relative a phpMyAdmin, metodo HTTP TRACE attivo e diversi header HTTP di sicurezza mancanti.

I risultati di Nikto rappresentano segnalazioni ottenute mediante scansione automatizzata e devono essere considerati elementi da verificare ulteriormente, non necessariamente vulnerabilità sfruttabili.

```
(kali@kali) [~]
$ nikto -h http://192.168.50.101
- Nikto v2.6.1

+ Target IP: 192.168.50.101
+ Target Hostname: 192.168.50.101
+ Target Port: 80
+ Platform: Unknown
+ Start Time: 2026-09-20 06:58:35 (GMT-4)

+ Server: Apache/2.2.8 (Ubuntu) DAV/2
+ ERROR: Failed to check for updates:
+ [000287] /: Retrieved x-powered-by header: PHP/5.2.4-2ubuntu5.10.
+ [750500] /icons/: Directory indexing found. See: CWE-548
+ No CGI Directories found (use '-C all' to force check all possible dirs). CGI tests skipped.
+ [999967] /: Web Server returns a valid response with junk HTTP methods which may cause false positives.
+ [000434] /: HTTP TRACE method is active and replies which suggests the host is vulnerable to XST. See: https://owasp.org/www-community/attacks/Cross_Site_Tracing
+ [013587] /: Suggested security header missing: permissions-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-Policy
+ [013587] /: Suggested security header missing: content-security-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP
+ [013587] /: Suggested security header missing: strict-transport-security. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Security
+ [013587] /: Suggested security header missing: referrer-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referrer-Policy
+ [013587] /: Suggested security header missing: x-content-type-options. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Content-Type-Options
+ [999100] /index: Uncommon header(s) 'tcn' found, with contents: list.
+ [999965] /index: Apache mod_negotiation is enabled with MultiViews, which allows attackers to easily brute force file names. The following alternatives for 'index' were found: index.php. See: https://exchange.xforce.ibmcloud.com/vulnerabilities/8275
+ [600625] PHP/5.2.4-2ubuntu5.10 appears to be outdated (current is at least 8.5.8).
+ [600050] Apache/2.2.8 appears to be outdated (current is at least 2.4.68).
+ [750510] /phpinfo.php: Output from the phpinfo() function was found.
+ [750500] /doc/: Directory indexing found. See: CWE-548
+ [001213] /doc/: The /doc/ directory is browsable. This may be /usr/doc. See: https://nvd.nist.gov/vuln/detail/CVE-1999-0678
+ [01384] /?PHPBB5F2A0-3C92-11d3-A3A9-4C7B08C10000: PHP Easter Eggs reveals potentially sensitive information via HTTP
```

```
+ [01384] /?PHPBB5F2A0-3C92-11d3-A3A9-4C7B08C10000: PHP Easter Eggs reveals potentially sensitive information via HTTP requests that contain specific QUERY strings. See: https://labs.detectify.com/writeups/do-you-dare-to-show-your-php-easter-egg/
+ [01385] /?PHPE9568F36-D428-11d2-A769-00AA001ACF42: PHP Easter Egg reveals potentially sensitive information via HTTP requests that contain specific QUERY strings. See: https://labs.detectify.com/writeups/do-you-dare-to-show-your-php-easter-egg/
+ [01386] /?PHPE9568F34-D428-11d2-A769-00AA001ACF42: PHP Easter Egg reveals potentially sensitive information via HTTP requests that contain specific QUERY strings. See: https://labs.detectify.com/writeups/do-you-dare-to-show-your-php-easter-egg/
+ [01387] /?PHPE9568F35-D428-11d2-A769-00AA001ACF42: PHP Easter Egg reveals potentially sensitive information via HTTP requests that contain specific QUERY strings. See: https://labs.detectify.com/writeups/do-you-dare-to-show-your-php-easter-egg/
+ [001795] /phpMyAdmin/changelog.php: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
+ [999984] /phpMyAdmin/ChangeLog: Server may leak inodes via ETags, header found with file /phpMyAdmin/ChangeLog, inode: 92462, size: 40540, mtime: Tue Dec 9 12:24:00 2008. See: https://nvd.nist.gov/vuln/detail/CVE-2003-1418
+ [001796] /phpMyAdmin/ChangeLog: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
+ [750500] /test/: Directory indexing found. See: CWE-548
+ [001894] /test/: This might be interesting.
+ [002989] /phpinfo.php: PHP is installed, and a test script which runs phpinfo() was found. This gives a lot of system information. See: CWE-552
+ [003584] /icons/README: Apache default file found. See: https://www.vntweb.co.uk/apache-restricting-access-to-iconsreadme/
+ [006672] /phpMyAdmin/Documentation.html: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
+ [007107] /phpMyAdmin/README: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts. See: https://typo3.org/
+ [007342] /: X-Frame-Options header is deprecated and was replaced with the Content-Security-Policy HTTP header with the frame-ancestors directive. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/X-Frame-Options
+ [007352] /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/mis-sing-content-type-header/
+ 8235 requests: 0 errors and 31 items reported on the remote host
+ End Time: 2026-09-20 06:59:13 (GMT-4) (38 seconds)

+ 1 host(s) tested
```

## 11. Enumerazione SMB con Enum4linux

Poiché erano state rilevate le porte SMB 139 e 445, è stata eseguita un'enumerazione mediante:

```
enum4linux -a 192.168.50.101
```

Lo strumento ha consentito di raccogliere numerose informazioni tramite SMB, tra cui il nome **METASPLOITABLE**, informazioni relative a **Samba 3.0.20-Debian**, account e gruppi presenti sul sistema e informazioni relative alla password policy.

Sono state inoltre individuate diverse condivisioni:

- print\$
- tmp
- opt
- IPC\$
- ADMIN\$

L'enumerazione ha mostrato anche numerosi account, tra cui **root**, **user**, **www-data**, **postgres**, **mysql**, **ftp**, **tomcat55** e altri account di sistema.

La quantità di informazioni ottenute senza autenticazione evidenzia quanto il servizio SMB possa contribuire alla fase di Information Gathering.

---

## 12. Enumerazione RPC

Infine è stato utilizzato **rpcinfo**:

```
rpcinfo -p 192.168.50.101
```

L'opzione **-p** interroga il portmapper/RPCbind del target per ottenere l'elenco dei programmi RPC registrati.

Sono stati individuati diversi servizi, tra cui:

- 111/tcp portmapper
- 2049/tcp nfs
- 39321/tcp status
- 37392/tcp nlockmgr
- 44506/tcp mountd

Questi risultati hanno inoltre confermato l'identificazione di alcune delle porte alte precedentemente rilevate con Nmap.

---

# Riepilogo finale

L'attività di Information Gathering sulla macchina Metasploitable (192.168.50.101) ha permesso di ottenere una panoramica dettagliata della superficie di rete esposta.

La scansione completa ha individuato **30 porte TCP aperte** e numerosi servizi, tra cui FTP, SSH, Telnet, HTTP, SMB, NFS, MySQL, PostgreSQL, VNC, IRC, RPC e servizi Java. Il sistema operativo è stato identificato da Nmap come appartenente alla famiglia **Linux 2.6.x**.

L'analisi delle versioni ha evidenziato diversi software, tra cui **vsFTPD 2.3.4**, **OpenSSH 4.7p1**, **Apache 2.2.8**, **PHP 5.2.4**, **MySQL 5.0.51a**, **ProFTPD 1.3.1** e **UnrealIRCd**.

L'analisi del servizio web mediante WhatWeb e Nikto ha inoltre evidenziato diverse informazioni sulla configurazione HTTP e sulle tecnologie installate. Enum4linux ha consentito di raccogliere informazioni tramite SMB, comprese condivisioni, account e configurazioni relative alle password, mentre Rpcinfo ha permesso di identificare i servizi RPC disponibili.

L'utilizzo combinato dei diversi strumenti ha dimostrato come la fase di **Information Gathering** permetta di ottenere informazioni progressivamente più dettagliate sul target, partendo dalla semplice individuazione delle porte fino all'identificazione di sistemi operativi, versioni software, tecnologie web, account, condivisioni e servizi di rete.

**Vincenzo Lembo**